

## Informe CTEM.

La CTEM se está consolidando desde 2025 como el marco de referencia para pasar de “gestionar vulnerabilidades” a gobernar, con mala leche metódica, la exposición real a amenazas de un país, un sector o una organización concreta. Lo interesante, para un informe de ámbito nacional como el que propones para España, es que la conversación ya no va de controles, sino de indicadores: qué medimos, cómo lo medimos y a quién le duele el número cuando sale mal.<sup>1234</sup>

### 1. Recordatorio rápido: qué entiende el mundo por CTEM

Gartner formaliza CTEM en torno a cinco fases continuas: alcance, descubrimiento, priorización, validación y movilización, con el objetivo explícito de producir un plan de mejora de postura que un comité de dirección entienda y que los arquitectos puedan ejecutar. La tesis es brutalmente pragmática: como no puedes arreglarlo todo, céntrate en la fracción de exposición que un adversario razonable explotaría primero, y mide si esa fracción se reduce con el tiempo.<sup>56</sup>

A partir de 2025, esta lógica se ha encarnado en el mercado bajo la etiqueta de “exposure assessment platforms” (EAP), que introducen cuadros de mando de riesgo, consolidación de fuentes (vulnerabilidades, configuración, amenazas, negocio) y, sobre todo, KPIs de ciclo de vida: SLA de remediación, MTTR, velocidad de remediación y reducción de superficie.<sup>789</sup>

---

1 <https://www.scribd.com/document/995272637/Gartner-2025-05-Use-CTEM-to-Reduce-Cyberattacks>

2 <https://es-la.tenable.com/cybersecurity-guide/learn/what-is-ctem>

3 <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>

4 <https://simspace.com/blog/gartners-ctem-trend-explained-for-real-security-teams/>

5 <https://www.scribd.com/document/995272637/Gartner-2025-05-Use-CTEM-to-Reduce-Cyberattacks>

6 <https://cyesec.com/blog/exposure-management>

7 <https://nucleussec.com/blog/eaps-are-here-big-part-successful-ctem/>

8 <https://dataintel.com/report/continuous-threat-exposure-management-market>

9 <https://patrowl.io/en/continuous-threat-exposure-management-ctem>

## 2. De métricas de vulnerabilidades a indicadores CTEM

La transición de métricas “clásicas” (número de vulnerabilidades, porcentaje de sistemas parcheados) a indicadores CTEM viene marcada por tres obsesiones: contexto, continuidad y explotabilidad.<sup>101112</sup>

### 1. Contexto de negocio

CTEM fuerza a que cualquier número se interprete frente a activos críticos y procesos de negocio, no en el vacío técnico. La priorización se apoya en sistemas como CVSS, EPSS o la NVD, pero ponderados por impacto en servicios críticos y presencia de amenazas activas. Dicho de otro modo: ya no importa tanto si tienes mil vulnerabilidades, sino cuántas rutas de ataque efectivas conducen, hoy, a tu “joya de la corona”.<sup>95</sup>

### 2. Continuidad y cadencia

El énfasis se desplaza desde auditorías puntuales a observabilidad continua de la exposición externa e interna, en línea con la evolución del mercado CTEM, que crece ligado a modelos cloud y SaaS y a un uso intensivo de automatización. Las métricas pasan a tener componente de cadencia (tiempo, frecuencia, tendencia) más que de instantánea; lo que se presenta a dirección es una curva, no una foto.<sup>78106</sup>

### 3. Explotabilidad real

Las fases de validación introducen métricas sobre qué porcentaje de las exposiciones detectadas pueden explotarse de forma creíble, usando simulación de brechas, BAS y pruebas automatizadas. El indicador deja de ser “vulnerabilidades críticas abiertas” y pasa a ser “rutas de ataque explotables hacia activos críticos y su tiempo medio de cierre”, que es una forma más honesta de decir “qué probabilidades tengo de salir mañana en los periódicos”.<sup>359</sup>

## 3. Indicadores CTEM “core” (organización)

Aunque no existe todavía un estándar formal universal de indicadores CTEM, a partir de 2025 empiezan a converger los mismos bloques métricos en informes de analistas, plataformas EAP y guías para CISOs. A nivel micro (organización) los indicadores suelen agruparse alrededor de seis ejes.<sup>131415</sup>

---

<sup>10</sup> <https://cyesec.com/blog/exposure-management>

<sup>11</sup> <https://simspace.com/blog/gartners-ctem-trend-explained-for-real-security-teams/>

<sup>12</sup> <https://www.scribd.com/document/995272637/Gartner-2025-05-Use-CTEM-to-Reduce-Cyberattacks>

<sup>13</sup> <https://simspace.com/blog/gartners-ctem-trend-explained-for-real-security-teams/>

<sup>14</sup> <https://nucleussec.com/blog/eaps-are-here-big-part-successful-ctem/>

<sup>15</sup> <https://cyesec.com/blog/exposure-management>

4.  
Exposición y superficie de ataque  
Aquí se mide la cantidad y calidad de lo que está expuesto al mundo (o al menos a actores con cierto nivel de acceso). Indicadores típicos:
5.  
Número de activos descubiertos en superficie externa (dominios, subdominios, IP, servicios expuestos) y porcentaje de ellos inicialmente desconocidos (shadow IT).<sup>85</sup>
6. Proporción de activos críticos con exposición directa a Internet o a terceros, lo que enlaza muy bien con obligaciones como NIS2 y DORA.<sup>8</sup>
7.  
Número de vectores de ataque distintos identificados hacia un mismo activo crítico (por ejemplo, combinando vulnerabilidades, credenciales expuestas y errores de configuración).<sup>59</sup>
8.  
Vulnerabilidades y debilidades en contexto  
La métrica “bruta” de vulnerabilidades sigue ahí, pero CTEM la refina:
9.  
Densidad de vulnerabilidades de alta prioridad por activo crítico (en lugar de “en todo el parque”), usando CVSS/EPSS y mapeo a procesos de negocio.<sup>5</sup>
10. Porcentaje de vulnerabilidades asociadas a amenazas activas según inteligencia (por ejemplo, vulnerabilidades ya integradas en kits de explotación).<sup>9</sup>
11.  
Exposiciones no CVE: credenciales expuestas, configuraciones por defecto, protocolos obsoletos, servicios sombra, todo ello cuantificado como “issues de exposición” en los cuadros de mando.<sup>85</sup>
12.  
Prioridad y backlog de exposición  
A CTEM le interesa el backlog de lo que de verdad importa:
13.  
Volumen de exposiciones clasificadas como “críticas para el negocio” pendientes de remediación, y su antigüedad.<sup>65</sup>
14.  
Ratio de exposiciones “validadas como explotables” frente al total detectado, desglosado por dominio (red, aplicaciones, identidad, terceros).<sup>39</sup>

15.  
Eficacia de remediación (los números que acaban en el comité de dirección)  
Las plataformas CTEM y EAP coinciden en un conjunto de KPIs de ciclo de vida:
16.  
Cumplimiento de SLA de remediación para exposiciones críticas y altas, medido como porcentaje cerrado en el plazo acordado.<sup>6</sup>
17. Mean Time To Remediate (MTTR) de exposiciones priorizadas, separado de la métrica genérica de “tiempo de parcheo”.<sup>106</sup>
18.  
Velocidad de remediación (remediation velocity): cuánto riesgo agregado se reduce por unidad de tiempo, a menudo calculado como disminución del score de exposición en activos críticos por semana o mes.<sup>106</sup>
19.  
Validación y “realidad adversarial”  
Aquí aparece toda la parte menos cómoda:
20.  
Tasa de éxito de ejercicios de BAS o simulación de ataques frente a rutas de ataque identificadas en CTEM.<sup>93</sup>
21. Porcentaje de controles de seguridad que fallan frente a escenarios de ataque modelados (MITRE ATT\&CK, técnicas específicas, etc.).<sup>9</sup>
22.  
Tiempo medio en detectar desviaciones significativas en la superficie de ataque (por ejemplo, nuevos servicios expuestos o cambios de configuración críticos).<sup>85</sup>
23.  
Resultados de negocio y riesgo residual  
Los analistas han insistido en anclar CTEM a resultados observables:
24.  
Reducción del número de incidentes graves o brechas exitosas en organizaciones con CTEM maduro, estimado por Gartner como una reducción de hasta 3 veces la probabilidad de brecha para 2026.<sup>3</sup>
25. Evolución del nivel de riesgo residual, medido mediante índices internos de exposición o mediante correlación entre incidentes y medidas de mitigación implementadas.<sup>109</sup>

## Exposición y superficie de ataque

Aquí se mide la cantidad y calidad de lo que está expuesto al mundo (o al menos a actores con cierto nivel de acceso). Indicadores típicos:

Número de activos descubiertos en superficie externa (dominios, subdominios, IP, servicios expuestos) y porcentaje de ellos inicialmente desconocidos (shadow IT).<sup>1617</sup>

Número de vectores de ataque distintos identificados hacia un mismo activo crítico (por ejemplo, combinando vulnerabilidades, credenciales expuestas y errores de configuración).<sup>1819</sup>

## Vulnerabilidades y debilidades en contexto

La métrica “bruta” de vulnerabilidades sigue ahí, pero CTEM la refina:

Densidad de vulnerabilidades de alta prioridad por activo crítico (en lugar de “en todo el parque”), usando CVSS/EPSS y mapeo a procesos de negocio.<sup>20</sup>

Exposiciones no CVE: credenciales expuestas, configuraciones por defecto, protocolos obsoletos, servicios sombra, todo ello cuantificado como “issues de exposición” en los cuadros de mando.<sup>2122</sup>

## Prioridad y backlog de exposición

A CTEM le interesa el backlog de lo que de verdad importa:

Volumen de exposiciones clasificadas como “críticas para el negocio” pendientes de remediación, y su antigüedad.<sup>2324</sup>

Ratio de exposiciones “validadas como explotables” frente al total detectado, desglosado por dominio (red, aplicaciones, identidad, terceros).<sup>2526</sup>

---

16 <https://patrowl.io/en/continuous-threat-exposure-management-ctem>

17 <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>

18 <https://cyesec.com/blog/exposure-management>

19 <https://cyesec.com/blog/exposure-management>

20 <https://cyesec.com/blog/exposure-management>

21 <https://patrowl.io/en/continuous-threat-exposure-management-ctem>

22 <https://cyesec.com/blog/exposure-management>

23 <https://nucleussec.com/blog/eaps-are-here-big-part-successful-ctem/>

24 <https://cyesec.com/blog/exposure-management>

25 <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>

Eficacia de remediación (los números que acaban en el comité de dirección)

Las plataformas CTEM y EAP coinciden en un conjunto de KPIs de ciclo de vida:

Cumplimiento de SLA de remediación para exposiciones críticas y altas, medido como porcentaje cerrado en el plazo acordado.<sup>27</sup>

Velocidad de remediación (remediation velocity): cuánto riesgo agregado se reduce por unidad de tiempo, a menudo calculado como disminución del score de exposición en activos críticos por semana o mes.<sup>2829</sup>

Validación y “realidad adversarial”

Aquí aparece toda la parte menos cómoda:

Tasa de éxito de ejercicios de BAS o simulación de ataques frente a rutas de ataque identificadas en CTEM.<sup>3031</sup>

Tiempo medio en detectar desviaciones significativas en la superficie de ataque (por ejemplo, nuevos servicios expuestos o cambios de configuración críticos).<sup>3233</sup>

Resultados de negocio y riesgo residual

Los analistas han insistido en anclar CTEM a resultados observables:

Reducción del número de incidentes graves o brechas exitosas en organizaciones con CTEM maduro, estimado por Gartner como una reducción de hasta 3 veces la probabilidad de brecha para 2026.<sup>34</sup>

#### 4. Del micro al macro: indicadores CTEM a escala país

Si uno se toma en serio aplicar CTEM a nivel nacional para España, el juego consiste en agregar, anonimizar y normalizar esos indicadores organizacionales en algo útil para política pública, todo ello en diálogo con el entorno europeo. La Agencia de Ciberseguridad de la UE (ENISA) ha dado un paso en

---

<sup>26</sup> <https://cyesec.com/blog/exposure-management>

<sup>27</sup> <https://nucleussec.com/blog/eaps-are-here-big-part-successful-ctem/>

<sup>28</sup> <https://www.recordedfuture.com/blog/ciso-guide-continuous-threat-exposure-management>

<sup>29</sup> <https://nucleussec.com/blog/eaps-are-here-big-part-successful-ctem/>

<sup>30</sup> <https://cyesec.com/blog/exposure-management>

<sup>31</sup> <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>

<sup>32</sup> <https://nucleussec.com/blog/eaps-are-here-big-part-successful-ctem/>

<sup>33</sup> <https://cyesec.com/blog/exposure-management>

<sup>34</sup> <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>

esa dirección con su Threat Landscape 2025, adoptando un enfoque más “centrado en la amenaza” y basado en el análisis de casi 4.900 incidentes en el periodo 2024–2025, lo que ofrece una base empírica para definir métricas de exposición a nivel europeo.<sup>353637</sup>

En ese contexto, los indicadores CTEM de nivel país tienden a alinearse con cuatro dimensiones: exposición sistémica, madurez de gestión, resiliencia y alineamiento normativo. Traducido al castellano peninsular: cuánto estamos expuestos, qué demonios hacemos al respecto, cuán rápido nos levantamos después del golpe, y si todo esto encaja con lo que Bruselas y las normas internacionales consideran aceptable.<sup>383940</sup>

#### 4.1 Exposición sistémica y superficie nacional

A partir de los patrones sectoriales que ENISA identifica (por ejemplo, la concentración de ataques en administraciones públicas y otros sectores esenciales), se pueden derivar indicadores CTEM a nivel estatal como:

- Proporción de incidentes graves en sectores regulados (NIS2, DORA, etc.) frente al resto, como indicador indirecto de exposición residual pese a obligaciones reforzadas.<sup>412</sup>
- Nivel de concentración de incidentes por tipo de amenaza (ransomware, intrusión, DDoS, etc.) y por sector, que permite calibrar dónde la exposición es estructural y no mera anécdota.<sup>114</sup>
- Número de activos críticos catalogados en infraestructuras esenciales y servicios clave, y porcentaje de ellos con gestión formal de exposición continua (por ejemplo, organizaciones que han adoptado programas CTEM, aunque sea bajo otra etiqueta).<sup>78</sup>

#### 4.2 Madurez CTEM y capacidad de remediación

El segundo bloque se inspira en lo que las plataformas CTEM miden en empresa, pero agregado por sectores y país:

---

<sup>35</sup> <https://simspace.com/blog/gartners-ctem-trend-explained-for-real-security-teams/>

<sup>36</sup> <https://es-la.tenable.com/cybersecurity-guide/learn/what-is-ctem>

<sup>37</sup> <https://dataintelo.com/report/continuous-threat-exposure-management-market>

<sup>38</sup> <https://www.scribd.com/document/995272637/Gartner-2025-05-Use-CTEM-to-Reduce-Cyberattacks>

<sup>39</sup> <https://simspace.com/blog/gartners-ctem-trend-explained-for-real-security-teams/>

<sup>40</sup> <https://patrowl.io/en/continuous-threat-exposure-management-ctem>

- Tiempo medio de remediación de exposiciones críticas en entidades reguladas, inferido a partir de datos supervisores u observaciones del mercado de CTEM.<sup>76</sup>
- Cobertura de descubrimiento y gestión de superficie de ataque (porcentaje de entidades esenciales con capacidades de descubrimiento continuo de activos y exposición externa).<sup>8</sup>
- Indicadores de capacidad de respuesta basada en inteligencia de amenazas, como la proporción de incidentes donde se aplicaron medidas proactivas informadas por ciberinteligencia antes de la explotación completa, algo que se subraya en informes industriales sobre el “nuevo paradigma” CTEM.<sup>1312</sup>

#### 4.3 Resiliencia y continuidad de negocio digitales

A nivel europeo se insiste en la resiliencia como resultado observable: supervivencia ordenada pese al caos. En un marco CTEM territorial para España tendría sentido medir:<sup>4142</sup>

- Tiempo medio de restauración de servicios digitales esenciales tras incidentes relevantes, desglosado por sector.<sup>114</sup>
- Porcentaje de incidentes que generan interrupción significativa del servicio o impacto ciudadano, frente a aquellos contenidos sin afectación externa notable.<sup>412</sup>
- Nivel de preparación ante escenarios sistémicos (por ejemplo, ataques coordinados sobre múltiples organismos de la administración), con indicadores ligados a ejercicios nacionales y tests de estrés cibernéticos que, aunque hoy se miden más cualitativamente, podrían integrarse como métricas CTEM sobre “validación” a escala país.<sup>144</sup>

#### 4.4 Alineamiento normativo y gobernanza del riesgo

Finalmente, un país europeo no puede hablar de CTEM sin mencionar la feliz tríada NIS2, DORA e ISO 27001, que los proveedores CTEM ya explotan como eje de reporting. A nivel nacional resultan relevantes:<sup>4344</sup>

- Porcentaje de entidades sujetas a NIS2 y DORA que integran métricas de exposición continua en sus informes regulatorios y de consejo, más allá del clásico checklist de cumplimiento.<sup>128</sup>
- Grado de uso de marcos como MITRE ATT&CK y NIST CSF en la definición de métricas CTEM organizacionales, lo que facilita su agregación y comparabilidad a nivel europeo.<sup>159</sup>
- Indicadores de transparencia y reporte: número de incidentes significativos notificados, tiempos de notificación, y calidad de la información útil para alimentar métricas CTEM nacionales.<sup>114</sup>

---

<sup>41</sup> <https://www.scribd.com/document/995272637/Gartner-2025-05-Use-CTEM-to-Reduce-Cyberattacks>

<sup>42</sup> <https://simspace.com/blog/gartners-ctem-trend-explained-for-real-security-teams/>

<sup>43</sup> <https://cyesec.com/blog/exposure-management>

<sup>44</sup> <https://patrowl.io/en/continuous-threat-exposure-management-ctem>



Tabla orientativa (macro vs micro)

| Dimensión                   | Indicadores típicos CTEM organización                                                | Indicadores CTEM a nivel país (España)                                                            |
|-----------------------------|--------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|
| <b>Superficie de ataque</b> | Activos descubiertos, servicios expuestos, shadow IT. <sup>85</sup>                  | Activos críticos catalogados y cobertura CTEM en sectores esenciales. <sup>74</sup>               |
| <b>Exposición</b>           | Vulnerabilidades priorizadas por negocio, rutas de ataque explotables. <sup>59</sup> | Incidentes graves por sector y tipo de amenaza, concentración sistémica. <sup>411</sup>           |
| <b>Remediación</b>          | SLA cumplidos, MTTR, velocidad de remediación. <sup>610</sup>                        | Tiempo medio de remediación en regulados, capacidades de descubrimiento continuo. <sup>68</sup>   |
| <b>Validación</b>           | Éxito de BAS, eficacia de controles, detección de desviaciones. <sup>39</sup>        | Resultados de ejercicios nacionales, validación de escenarios sistémicos. <sup>414</sup>          |
| <b>Resiliencia</b>          | Reducción de brechas, continuidad de servicios críticos. <sup>310</sup>              | Tiempo de restauración de servicios esenciales, impacto ciudadano de incidentes. <sup>412</sup>   |
| <b>Gobernanza</b>           | Uso de MITRE/NIST, reporting ejecutivo de exposición. <sup>159</sup>                 | Integración de métricas CTEM en marcos NIS2/DORA/ISO, calidad de reporte nacional. <sup>811</sup> |

## 5. Tendencias 2025–2026 en indicadores CTEM (y cómo encajan con España)

Desde 2025 se observan algunas tendencias claras en la formulación de indicadores que afectan directamente a cómo un país como España puede diseñar su propio “cuadro de mando CTEM”.<sup>454647</sup>

Primero, la industrialización del riesgo. El mercado CTEM crece acompañado de informes que señalizan un aumento de la superficie de ataque, la sofisticación (ransomware-as-a-service, ataques impulsados por IA) y la necesidad de respuestas basadas en exposición real, no en percepciones. Para España, esto se traduce en la necesidad de indicadores que reflejen la adopción de CTEM en sectores claves como financiero, sanitario, administración pública y operadores críticos, vinculando métricas de exposición a programas nacionales de digitalización y nube.<sup>4849</sup>

Segundo, el giro hacia la ciberinteligencia y la amenaza como marco organizador. Informes de industria elaborados junto a grandes proveedores subrayan el papel de la ciberinteligencia en CTEM: indicadores

<sup>45</sup> <https://simspace.com/blog/gartners-ctem-trend-explained-for-real-security-teams/>

<sup>46</sup> <https://nucleussec.com/blog/eaps-are-here-big-part-successful-ctem/>

<sup>47</sup> <https://dataintelo.com/report/continuous-threat-exposure-management-market>

<sup>48</sup> <https://dataintelo.com/report/continuous-threat-exposure-management-market>

<sup>49</sup> <https://simspace.com/blog/gartners-ctem-trend-explained-for-real-security-teams/>

que midan qué porcentaje de la exposición está vinculado a amenazas activas, qué indicadores de compromiso se detectan en entornos nacionales, y cómo se integra esa información en la priorización y la remediación.<sup>5051</sup>

Tercero, la europeización del vocabulario. ENISA y otros actores están empujando una lectura “amenaza-céntrica” del ecosistema europeo, ofreciendo datos comparables entre países que pueden alimentar indicadores nacionales sobre exposición y resiliencia. Esto ofrece a España la oportunidad de diseñar un marco de indicadores CTEM nacional perfectamente alineado con las taxonomías europeas de incidentes, sectores y tipos de amenaza, evitando inventarse otra lengua muerta más.<sup>52535455</sup>

Por último, el anclaje a resultados. Los analistas repiten el mantra: para 2026 quien priorice inversiones de seguridad siguiendo programas CTEM tendrá hasta tres veces menos probabilidades de sufrir una brecha grave. Esta promesa, que ya se está usando como argumento en informes de mercado y guías para CISOs, sugiere que los indicadores CTEM nacionales deberían aspirar a correlacionar la adopción de programas de exposición continua con la reducción observable de incidentes graves en el tejido económico y en la administración pública española.<sup>5657</sup>

Si pensamos en un informe CTEM nacional “a la española”, las encuestas inquisitivas no deberían preguntar solo “qué controles tiene usted” sino “qué curvas está mirando”: exposición priorizada, backlog de rutas de ataque, tiempos de cierre, impacto en continuidad de negocio, y, en última instancia, si eso ha cambiado la frecuencia con la que se apagan las luces.

161718192021222324252627282930

---

50 <https://www.recordedfuture.com/blog/ciso-guide-continuous-threat-exposure-management>

51 <https://www.northwestprotection.ca/post/ctem-the-ultimate-guide-to-continuous-threat-exposure-management-in-2024>

52 <https://simspace.com/blog/gartners-ctem-trend-explained-for-real-security-teams/>

53 [https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA Threat Landscape 2025\\_v1.2.pdf](https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA%20Threat%20Landscape%202025_v1.2.pdf)

54 <https://es-la.tenable.com/cybersecurity-guide/learn/what-is-ctem>

55 <https://patrowl.io/en/continuous-threat-exposure-management-ctem>

56 <https://www.digitalsme.eu/enisa-cybersecurity-threat-landscape-report-2025-key-takeaways-for-smes/>

57 <https://es.resources.computerworld.com/resources/hacia-un-nuevo-paradigma-de-ciberseguridad-impulsado-por-la-ciberinteligencia-y-el-nuevo-enfoque-ctem/>